

Fileless Malware – Practical 1

02-26-2025

Vandan Agrawal

vandan.agrawal@ufl.edu

Executive Summary:

This is a fileless malware, as in, it is not creating any files but directly executing in memory. It appears to be a remote access trojan as 1. It is a GUI programs so it definitely does something ‘useful’ in the front, and remote access because of the multiple requests made to and from the ip 207.148.76.235. The malware is seen to be accessing and using multiple DLLs continuously. The malware could be storing any data anywhere in the multiple files it is creating and accessing, and transmitting it to the given ip, or even retrieve and download some data from that address.

Static analysis:

- Analyze sample1.bin in PE studio (On windows 10) (Basic static analysis)

pestudio 9.46 - Malware Initial Assessment - www.winitor.com - [c:\users\malware\desktop\sample...

file settings about

c:\users\malware\desktop\sample1.bin

property	value
md5	62C34D36394FCA4878E021E76A7583CB
sha1	779E2CBAF9CC16CBD0A50B889ECCF293788F
sha256	C8F8CF5E6AB61B7E72FCC14B3E88FC87DA96
first-bytes-hex	4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 0
first-bytes-text	M Z
file-size	78336 bytes
entropy	6.279
imphash	6677DE6818BCF597D512AD4DDAEA3F53
signature	n/a
tooling	Visual Studio 2015
entry-point	55 8B EC 83 7D 0C 01 75 05 E8 83 01 00 00 FF 7
file-version	5.5.10.101
description	CyberArk Viewfinity
file-type	dynamic-link-library
cpu	32-bit
subsystem	GUI
compiler-stamp	Mon Jun 20 09:36:32 2022 UTC
debugger-stamp	Mon Jun 20 09:36:32 2022 UTC
resources-stamp	0x00000000
import-stamp	0x00000000
exports-stamp	0xFFFFFFFF

indicators (49)

virustotal (error)

dos-header (64 bytes)

dos-stub (192 bytes)

rich-header (checksum)

file-header (Intel-386)

optional-header (GUI)

directories (7)

sections (5)

libraries (2)

imports (flag)

exports (duplicate)

exceptions (n/a)

tls-callback (n/a)

relocations (1702)

.NET (n/a)

resources (2)

strings (1486) *

debug (3)

manifest (asInvoker)

version (VFTRACE.dll)

overlay (n/a)

The compilation date is Jun 20, 2022. It is a DLL file as stated in the file-type field.

pestudio 9.46 - Malware Initial Assessment - www.winator.com - [c:\users\malware\desktop\sample1.bin]

file settings about

property	value	detail
characteristics	0x0140	items
address-space-layout-randomization (ASLR)	0x0040	true
data-execution-prevention (DEP)	0x0100	true
code-integrity (CI)	0x0000	false
structured-exception-handling (SEH)	0x0000	false
windows-driver-model (WDM)	0x0000	false
terminal-server-aware (TSA)	0x0000	false
control-flow-guard (CFG)	0x0000	false
image-bound	0x0000	false
image-isolation	0x0000	false
High-Entropy	0x0000	false
AppContainer	0x0000	false
Control-flow Enforcement Technology Shadow Stack (/CETCOMPACT)	0x0000	false
general		
subsystem	0x0002	GUI
magic	0x010B	PE
file-checksum	0x000141D8	0x00020BD2 (expected)
entry-point	0x000017F6 (original-entry-point)	section: .text
base-of-code	0x00001000	section: .text
base-of-data	0x0000D000	section: .rdata
size-of-code	0x0000B200	45568 bytes
size-of-initialized-data	0x00008600	34304 bytes
size-of-uninitialized-data	0x00000000	0 bytes
size-of-image	0x00017000	94208 bytes
size-of-Headers	0x00000400	1024 bytes
size-of-stack-reserve	0x00100000	1048576 bytes
size-of-stack-commit	0x00001000	4096 bytes
size-of-heap-reserve	0x00100000	1048576 bytes
size-of-heap-commit	0x00001000	4096 bytes
section-alignment	0x00001000	4096 bytes
file-alignment	0x00000200	512 bytes
directories-count	0x00000010	16
LoaderFlags	0x00000000	0x00000000
Win32VersionValue	0x00000000	0x00000000
image-base	0x10000000	0x10000000
linker-version	14.16	14.16
os-version	6.0	Windows Server 2008
image-version	0.0	0.0
subsystem-version	6.0	6.0

This is a GUI program as mentioned in the subsystem field.

property	value	value	value	value	value
general					
name	.text	.rdata	.data	.rsrc	.reloc
md5	48AFD9B4EF10B5F14B2C10C...	25E04469283CFF4D9A8D91F...	8A5C1764D3D68E0963003D...	1E0C952D3A72E7EDCDA3B5...	41DFD851E9053A3876AA862...
entropy	6.612	4.991	1.835	3.800	6.486
file-ratio (98.69%)	58.17 %	30.72 %	3.27 %	1.96 %	4.58 %
raw-address	0x00000400	0x00008600	0x00011400	0x00011E00	0x00012400
raw-size (77312 bytes)	0x0000B200 (45568 bytes)	0x00005E00 (24064 bytes)	0x00000A00 (2560 bytes)	0x00000600 (1536 bytes)	0x00000E00 (3584 bytes)
virtual-address	0x00001000	0x0000D000	0x00013000	0x00015000	0x00016000
virtual-size (78721 bytes)	0x0000B0AB (45227 bytes)	0x00005D0C (23820 bytes)	0x0000129C (4764 bytes)	0x00000552 (1362 bytes)	0x00000DDC (3548 bytes)

PE Studio detects significant entropy in .text and .reloc sections of the file. .rdata also shows medium entropy. This entropy (Scale 0-8) indicates how likely it is that certain sections of the file are packed.

The DLL uses multiple redundant jumps and function definitions which never seem to be called from any of our functions of interest.

name	offset	value	type	implicit	relative
NtCreateSection	x	0x000127A0	305 (0x0131)	memory	implicit
NtMapViewOfSection	x	0x000127B2	409 (0x0199)	memory	implicit

Importing NtCreateSection and NtMapViewOfSection: These are frequently used for allocating executable memory where the malware unpacks itself. Legitimate software usually uses “CreateFileMappingA/W” or “MapViewOfFile” to achieve similar functionality. Here, the actual payload is suspected to be in **file1.conf**, however, it is encrypted.

The different sections are found to be:

1. .text: Highest entropy of all sections. This section usually contains the actual code but might also contain the payload in this case.
2. .rdata: Used mainly for importing the needed libraries.
3. .data: Contains global and static variables.

4. .rsrc: used for storing contents like icons, strings, embedded files, etc.
5. .reloc: Stores relocation data for ASLR. Relatively higher entropy suggests that this part might be tampered to conceal malicious payload.

Suspicious imports: Multiple suspicious function imports can be spotted. The use of **NtCreateSection** and **NtMapViewOfSection** has already been discussed. **VirtualProtect**'s use is also highly suspicious. It is making multiple changes to memory protection, and is probably used for writing data at some memory address 'param1', which is also evident by `_memset()`.

```
local_c = 0;
if (param_3 != 0) {
    BVar1 = VirtualProtect(param_1, param_3, 4, &local_c);
    if (BVar1 == 0) goto LAB_100013f1;
    _memset(param_1, 0, param_3);
    BVar1 = VirtualProtect(param_1, param_3, 2, &local_c);
    if (BVar1 == 0) goto LAB_100013f1;
}
BVar1 = VirtualProtect(param_1, param_3, 4, &local_c);
if (BVar1 != 0) {
    FUN_10003370(param_1, param_2, param_3);
    VirtualProtect(param_1, param_3, 0x20, &local_c);
}
LAB_100013f1:
```

Use of multiple other memory, execution, and dynamic-library related functions like **GetModuleFileNameA**, **GetProcessID**, **HeapFree**, etc. suggest there might be some kind of code injection taking place.

We can also see the use of functions like **IsDebuggerPresent**, **TerminateProcess**, **SetUnhandledExceptionFilter**, etc. which suggests that the malware author has taken anti-debugging and anti-detection measures.

```
local_324, EXCEPTION_FILTER_DEBUG = param_3;
BVar2 = IsDebuggerPresent();
SetUnhandledExceptionFilter((LPTOP_LEVEL_EXCEPTION_FILTER)0x0);
LVar3 = UnhandledExceptionFilter(&local_32c);
if (((LVar3 == 0) && (BVar2 == 0)) && (param_1 != -1)) {
    FUN_10001e29();
}
__security_check_cookie(uVar1 ^ (uint)&stack0xffffffffc);
return;
}
```

There were also few strings on interest in sample1. Most notably, file1.conf, whose reference was used to track the suspicious function, along with the above mentioned function calls.

From the for loop marked below, we can see that the file is getting xor decrypted with key 1.

```

}
puVar1 = (uint *)FUN_1000394d((uint)filesize, 1);
FUN_10003370(puVar1, filesize, (uint)filesize);
CloseHandle(hFileMappingObject);
CloseHandle(hFile);
for (local_10 = (uint *)0x0; local_10 < filesize; local_10 = (uint *)((int)local_10 + 1)) {
    *(byte *)((int)puVar1 + (int)local_10) = *(byte *)((int)puVar1 + (int)local_10) ^ 1;
}
*param_2 = (uint)filesize;
}
}
```

Upon decryption, another file is revealed with a peculiar mz header.

```

GNU nano 4.8
00000000: 0090 9090 9090 9090 904d 5a52 45e8 0000 .....MZRE...
00000010: 0000 5b89 df55 89e5 81c3 457d 0000 ffd3 ..[.U...E]...
00000020: 68f0 b5a2 5668 0400 0000 57ff d000 0000 h...Vh...W....
00000030: 0000 0000 0000 0000 0000 0000 0000 0000 .....
00000040: 0000 0000 00f0 0000 008d 52bb 49d5 5d76 .....R.I.]v
00000050: 4ce4 235a 277a 7632 1c97 a68d 66e7 c96a L.#Z'zv2...f..j
00000060: 8800 f946 15d2 dce4 de76 aa0b 7895 2cee ...F....v..x.,.
00000070: 77c2 3355 fff8 19a1 5db0 9479 d524 1671 w.3U....].y$.q
00000080: 6825 f327 ed64 8ce6 e122 6588 64a5 67af h%.'d...".e.d.g.
00000090: d09b 3ed6 01d2 b0d8 7f0f 1d40 da7a 2b3c ..>.....@.z+<
000000a0: 6d40 ceac 596a 1890 437b e4cc e419 f2d3 m@..Yj..C{.....
000000b0: 9d52 a247 4220 1d02 49ba b068 8910 b7f1 .R.GB ..I..h....
000000c0: 35e1 1d69 675d f884 cb43 4020 8348 925e 5..ig][...C@.H.^
000000d0: d0c2 981b e3df 1f2c 52c9 7fcb 7b8d b934 .....R...{..4
000000e0: c2c9 9c05 47dc 0c93 db8c ac7e ad4d 9652 ....G.....~.M.R
000000f0: fa36 42a8 2e6d d16a fc4e 4f00 004c 0104 .6B..m.j.NO[L.L.
00000100: 00c0 d324 5800 0000 00c3 ffff ffe0 0003 ...$.X.....
00000110: 310b 0109 0000 5402 0000 6601 0000 0000 1.....T...f....
00000120: 00c0 ed09 0000 1000 0000 7002 0000 0000 .....p.....
00000130: 1000 1000 0000 0200 0005 0000 0000 0000 .....
00000140: 0005 0000 0000 0000 0000 2047 0000 0400 .....G....

```

There is a lot of entropy (highlighted section) after the MZ, and a bunch of ‘90’s (indicating nops). This indicates some form of further encryption. There is suspected to be some form of shell code here. Analyzing the file for strings, some interesting ones show up, most notably, names of months, and multiple error statements.

[illegible]

Dynamic analysis:

There are multiple entry points in the DLL (28 to be exact). After renaming sample1.bin to sample1.dll, procmon was run on the side and the command 'rundll32.exe sample1.dll, #n' was executed where n is values from 1-28. Procmon was filtered to only show rundll32.exe processes, and running it at ordinal 16, it tried to access and create file1.conf. This indicates that this is our function of interest (whose header is an overloaded '<<' operator). It fails to access file1.conf with an error that it doesn't exist in system32. So, both file1.conf and sample1.dll were copied to system32, and the command was rerun

Process Name	Process ID	Local Address	Remote Address	Local Port	Remote Port	Protocol	State
Isass.exe (5...)	2022Malware7-2	49156				TCP6	Listen
rundll32.ex...	2022Malware7-2	49200	235.76.148.207.in-addr.arpa	443		TCP	SYN sent
rundll32.ex...	2022Malware7-2	49201	235.76.148.207.in-addr.arpa	443		TCP	SYN sent
services.ex...	2022Malware7-2	49155				TCP	Listen
services.ex...	2022Malware7-2	49155				TCP6	Listen

The following registry keys and values were added.

```

Keys added:3
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\00-50-56-87-f8-15 Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564\00-50-56-87-f8-15

Values added:7
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\00-50-56-87-f8-15\wpaddecisionReason:0x00000001
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\00-50-56-87-f8-15\wpaddecisionTime:41 41 F0 C7 F1 88 D6 01
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\00-50-56-87-f8-15\wpaddecisionType:0x00000000
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564\wpaddecisionReason:0x00000001
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564\wpaddecisionTime:41 41 F0 C7 F1 88 D6 01
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564\wpaddecisionType:0x00000000
HKU\S-1-5-21-118134989-2631507447-87320884-1000\Software\Microsoft\Windows\CurrentVersion\Internet Settings\wpad\A93C2D0D-B228-4363-82E8-3ECAD0389564\NewVersion

```

All additions were seen in wpad. There were also some other values modified, which aren't of interest.

The IP address appears reversed in process hacker. The requests are analysed in wireshark (with fakedns and inetsim running)

No.	Time	Source	Destination	Protocol	Length	Info
313	52.989387665	192.168.245.130	207.148.76.235	TCP	62	49340 → 443 [FIN, ACK] Seq=1105 Ack=2328 Win=65024 Len=0
314	52.989387666	192.168.245.130	207.148.76.235	TCP	62	49339 → 443 [RST, ACK] Seq=1106 Ack=2351 Win=0 Len=0
316	52.243204965	192.168.245.130	192.168.245.133	TCP	62	[TCP Retransmission] 49340 → 80 [FIN, ACK] Seq=190 Ack=419 Win=65280 Len=0
317	52.243252995	192.168.245.130	192.168.245.130	TCP	56	80 → 49340 [ACK] Seq=410 Ack=197 Win=64128 Len=0
321	52.347681895	192.168.245.130	207.148.76.235	TCP	68	49341 → 443 [SYN] Seq=0 Win=0 Len=0 MSS=1460 WS=256 SACK_PERM=1
322	52.347726427	207.148.76.235	192.168.245.130	TCP	68	443 → 49341 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM=1 WS=128
323	52.347972959	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [ACK] Seq=1 Ack=1 Win=65536 Len=0
324	52.348179597	192.168.245.130	207.148.76.235	TLSv1.2	248	Client Hello
325	52.348197619	207.148.76.235	192.168.245.130	TCP	56	443 → 49341 [ACK] Seq=1 Ack=193 Win=64128 Len=0
326	52.358863777	207.148.76.235	192.168.245.130	TLSv1.2	1857	Server Hello, Certificate, Server Key Exchange, Server Hello Done
327	52.400059770	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [ACK] Seq=198 Ack=1802 Win=65536 Len=0
328	52.400059797	192.168.245.130	207.148.76.235	TLSv1.2	374	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
329	52.400079584	207.148.76.235	192.168.245.130	TCP	56	443 → 49341 [ACK] Seq=1802 Ack=511 Win=64128 Len=0
330	52.404210315	207.148.76.235	192.168.245.130	TLSv1.2	107	Change Cipher Spec, Encrypted Handshake Message
331	52.404409669	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [ACK] Seq=511 Ack=1853 Win=65536 Len=0
332	52.404278831	192.168.245.130	192.168.245.133	TCP	68	49342 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1
333	52.404309388	192.168.245.133	192.168.245.130	TCP	68	80 → 49342 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM=1 WS=128
334	52.404529641	192.168.245.130	192.168.245.133	TCP	62	49342 → 80 [ACK] Seq=1 Ack=1 Win=65536 Len=0
335	52.404577771	192.168.245.130	192.168.245.133	HTTP	251	GET /msdnload/update/AS/ataiio/trusted/en/authrootst1.cab79c11a7b6791b8331 HTTP/1.1
336	52.404583722	192.168.245.133	192.168.245.130	TCP	56	80 → 49342 [ACK] Seq=1 Ack=196 Win=64128 Len=0
337	52.503148721	192.168.245.133	192.168.245.130	TCP	206	80 → 49342 [PSH, ACK] Seq=1 Ack=196 Win=64128 Len=150 [TCP segment of a reassembled PDU]
338	52.505736350	192.168.245.133	192.168.245.130	HTTP	314	HTTP/1.1 200 OK (text/html)
339	52.505895899	192.168.245.130	192.168.245.133	TCP	62	49342 → 80 [ACK] Seq=196 Ack=410 Win=65280 Len=0
340	52.506048555	192.168.245.130	192.168.245.133	TCP	62	49342 → 80 [FIN, ACK] Seq=196 Ack=410 Win=65280 Len=0
341	52.506061559	192.168.245.133	192.168.245.130	TCP	56	80 → 49342 [ACK] Seq=410 Ack=197 Win=64128 Len=0
342	52.521628390	192.168.245.130	207.148.76.235	TLSv1.2	650	Application Data
343	52.521649780	207.148.76.235	192.168.245.130	TCP	56	443 → 49341 [ACK] Seq=1853 Ack=1105 Win=64128 Len=0
344	52.539839074	207.148.76.235	192.168.245.130	TLSv1.2	236	Application Data
345	52.540030964	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [ACK] Seq=1105 Ack=2033 Win=65280 Len=0
346	52.540044379	207.148.76.235	192.168.245.130	TLSv1.2	343	Application Data
347	52.540247009	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [ACK] Seq=1105 Ack=2320 Win=65024 Len=0
348	52.540931423	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [FIN, ACK] Seq=1105 Ack=2320 Win=65024 Len=0
349	52.542734053	207.148.76.235	192.168.245.130	TLSv1.2	87	Encrypted Alert
350	52.542852020	192.168.245.130	207.148.76.235	TCP	62	49341 → 443 [RST, ACK] Seq=1106 Ack=2351 Win=0 Len=0

This set of requests are occurring in repetition. Includes TCP and TLS requests to 207.148.76.235 and also HTTP requests to and from the DNS. It looks like the malware is sending and receiving some data from 207.148.76.235, which is encrypted behind TLS.

No visible interesting behaviours could be seen in the infected system, except the recurring TCP requests observed using process hacker.

Indicators of Compromise:

Host based: no visible changes.

Network based indicators: Multiple TCP and TLS requests to 207.148.76.235, and a pattern in the requests.